THREAT ADVISORY

Check Point VPN and Management Flaws Under Active Exploitation

Attackers are exploiting a patched VPN remote code execution flaw and a separate management server zero-day. Both allow code execution before authentication, making targeted patching and compromise assessment urgent.

Source: **Check Point Security Advisory** · 22 Sep 2026
CVE-2026-85102 · CVE-2026-93616

Memori CTI

ACTIVE EXPLOITATION / CVSS 9.8

Active exploitation. Act now.

Both flaws can enable code execution without authentication. With exploitation reported and fixes available, reachable unpatched systems warrant immediate remediation and compromise assessment.

CISA KEV / 25 SEPTEMBER 2026

Both CVEs are in the Known Exploited Vulnerabilities catalog. The federal remediation deadline was set for 25 September 2026.

The deadline applies to covered US federal agencies. For other organizations, KEV inclusion is evidence for urgent prioritization, not a universal compliance deadline.

CVE-2026-85102 / VPN

A gateway flaw patched before the observed Spark exploitation attempts.

CVE-2026-93616 / MANAGEMENT

A zero-day used in limited attacks before its public disclosure and fix.

23 JUL	Management attacks observed
09 SEP	VPN fix released
12 SEP	Spark exploitation attempts begin
22 SEP	Joint advisory and management fix

GATEWAY EXPOSURE

When certificate checks fail.

CVE-2026-85102 affects certificate handling during VPN negotiation, creating a route to remote code execution before authentication.

EXPOSURE CHECK

Prioritize reachable Remote Access or Site-to-Site VPN services when the installed fix level is missing or unverified.

Security Gateway and Spark firewalls are in scope, including centrally and locally managed Spark deployments.

Administrators should assess their VPN configuration and installed fix level rather than relying on the product name alone.

Attempts against Spark customers used anonymizing services and certificates with recurring subject values. Those values support hunting, but they are not an exhaustive signature set.

FOLLOW THE SESSION

Review unusual certificate-based Mobile Access logins, then investigate associated internal port and service scans.

MANAGEMENT EXPOSURE

A different route to execution.

CVE-2026-93616 is a pre-authentication path traversal and file-upload vulnerability in the management web service.

A reachable vulnerable service can allow an attacker to upload and execute arbitrary scripts. This is a separate issue from the VPN certificate flaw, with a separate remediation path

AFFECTED MANAGEMENT PRODUCTS

Security Management Server / Multi-Domain Security Management Server / Log Server / Multi-Domain Log Server / SmartEvent

WHY THE ROLE MATTERS

Management systems administer security policies and infrastructure. As an analytical assessment, compromise here could undermine trust in centrally managed configurations; the advisory does not describe the actual outcomes of the July attacks.

PATCH CHANNEL WARNING

LivePatch Take 28/29 does not fix this vulnerability. A dedicated hotfix or corrected Jumbo Hotfix is required.

OPERATIONAL ANALYSIS

Prioritize by exposure and control.

Use reachability, system role and verified patch state together. CVSS alone cannot determine which asset needs attention first.

IMMEDIATE RESPONSE / SUSPICIOUS ACTIVITY

If an asset shows plausible exploitation evidence, begin incident response alongside remediation. Patching alone does not remove existing attacker access.

01 / REACHABILITY

Start with vulnerable VPN services reachable from untrusted networks and management services open beyond trusted administration paths. Internal-only placement reduces exposure, but access from a compromised host can still matter.

02 / SYSTEM ROLE

A gateway mediates network access; a management server controls security policy. Give management systems high priority where broad administrative control increases potential impact, even if they are not internet-facing.

03 / VERIFIED PATCH STATE

Treat an unknown fix level as unverified exposure. A validated fix lowers ongoing exploit risk, but historical exposure still calls for log review. End-of-support systems also need an upgrade or replacement plan.

REMEDIATION MATRIX

Match the fix to the flaw.

Take numbers are release-specific. VPN fixes and management fixes are not interchangeable.

01 VPN / CVE-2026-85102

Release / platform	Fix listed in coverage
R81.10	Jumbo Hotfix Take 190 or later
R81.20	Take 166 or later
R82	Take 126 or later
R82.10	Take 44 or later
Spark R82.00.x	R82.00.10 Build 2325 or later
Spark R81.10.x	R81.10.17 Build 4968 or later

LivePatch Take 26 is an alternative on supported R81.20, R82 and R82.10 gateways. Earlier offline packages may require this update for full coverage.

02 MANAGEMENT / CVE-2026-93616

Release	Required fix
R82.20	Dedicated Security Hotfix (TAR)
R82.10	Jumbo Hotfix Take 45 or later
R82	Take 127 or later
R81.20	Take 170 or later
R81.10 (end of support)	Take 192 or later

REMEDIATION ASSURANCE

Verify the fix. Review the past.

Validate each running system after deployment. Record its release, installed update and the outcome of the vendor checks.

VPN / CHECK THE INSTALLED LIVEPATCH BUNDLE

```
cpinfo -y CPupdates
```

Run in Expert mode on the Security Gateway. Compare the reported CPUpdates bundle and take with sk1000117; the advisory identifies Take 26 for the relevant urgent update. Earlier offline packages may need updating.

> **DO NOT CONFUSE INVENTORY WITH COMPLETE VALIDATION**
> This command lists installed update information. Complete the platform-specific LivePatch checks in the advisory; a bundle listing alone is not a compromise assessment.

MANAGEMENT / VERIFY THE SEPARATE HOTFIX

Confirm the dedicated R82.20 hotfix or the corrected Jumbo Hotfix take against the matrix. LivePatch Take 28/29 does not remediate CVE-2026-93616.

WHILE REMEDIATION IS UNDER WAY

Restrict management TCP/19009 to trusted IP addresses. Apply vendor VPN access restrictions where supported; the VPN workaround excludes locally managed Spark. Review logs from the period before patching.

HUNTING REFERENCE

Indicators & hunting clues

These observations guide investigation. A match should be interpreted in context; it is not automatically proof of a successful compromise.

01 **VPN / CERTIFICATE SUBJECTS**

CN=vpn,OU=users,O=global

CN=vpn-user,OU=users,O=global

CN=vpnuser,OU=users,O=global

Search beyond these three values. Correlate unusual Mobile Access authentication with subsequent internal port or service discovery.

MANAGEMENT / LOG CORRELATION

02 **LONG USERNAME + CORE DUMP**

Check cpm.elg for unusually long login usernames; correlate the event time with FWM/MDS core dumps.

03 **RESOURCE-LOADING ERRORS**

Investigate ReflectionUtils errors and suspicious paths containing directory traversal sequences such as ../.

Use the exact vendor queries in sk1000171. These are certificate and log-based clues, not a complete IP, domain or file-hash blocklist.

Stay vigilant. **Follow Memori CTI for more threat intel.**